

Blackthorn

Security Review For Morpho

Collaborative Audit Prepared For: **Morpho**

Lead Security Expert(s): **0x73696d616f**

pkqs90

xiaoming90

Date Audited: **September 10 - September 11, 2026**

Introduction

Security review focusing on the WhitelistEnterGate update of Morpho Midnight.

Scope

Repository: `sherlock-scoping/morpho-org__midnight`

Audited Commit: `70607569ac348e9880b512ffd3b574be55405932`

Final Commit: `ecadee4b52083c78cb3f3cac835da07644b8f4e0`

Files:

- `src/periphery/whitelist-enter-gate/interfaces/IWhitelistEnterGateFactory.sol`
- `src/periphery/whitelist-enter-gate/interfaces/IWhitelistEnterGate.sol`
- `src/periphery/whitelist-enter-gate/WhitelistEnterGateFactory.sol`
- `src/periphery/whitelist-enter-gate/WhitelistEnterGate.sol`

Final Commit Hash

`ecadee4b52083c78cb3f3cac835da07644b8f4e0`

Findings

Each issue has an assigned severity:

- High issues are directly exploitable security vulnerabilities that need to be fixed.
- Medium issues are security vulnerabilities that may not be directly exploitable or may require certain conditions in order to be exploited. All major issues should be addressed.
- Low/Info issues are non-exploitable, informational findings that do not pose a security risk or impact the system's integrity. These issues are typically cosmetic or related to compliance requirements, and are not considered a priority for remediation.

Issues Found

High	Medium	Low/Info
0	0	2

Issues Not Fixed and Not Acknowledged

High	Medium	Low/Info
0	0	0

Security Experts Dedicated to This Review

@0x73696d616f

A handwritten signature in white ink on a black background. The signature is stylized, starting with a large 'O' that loops around the word 'Simao'.

@pkqs90

A handwritten signature in white ink on a black background. The signature is highly stylized, featuring a large 'P' and 'k' that flow into each other, with 'qs90' written in a smaller, more legible script.

@xiaoming90

A handwritten signature in white ink on a black background. The signature is written in a cursive style, with the word 'Xiaoming' clearly visible, followed by '90'.

Issue L-1: Re-granting a whitelister role revives old signatures [ACKNOWLEDGED]

Source: <https://github.com/sherlock-audit2/2026-09-morpho-whitelistertergate-sep-9th-2026/issues/3>

This issue has been acknowledged by the team but won't be fixed at this time.

Summary

Revoking a whitelister does not cancel its outstanding signatures, so granting the role to the same address again revives every unexpired signature whose nonce is still current.

Root cause

`setIsWhitelister()` records only whether an address currently holds the role. Setting the flag to `false` does not advance a nonce or signer epoch. When the address is later re-enabled, `setIsWhitelistedWithSig()` cannot tell that the signature was issued under an earlier grant of the role.

Source: `setIsWhitelister()` and `setIsWhitelistedWithSig()`

```
function setIsWhitelister(bool creditSide, address account, bool newIsWhitelister)
↳ external {
    require(msg.sender == roleSetter[creditSide], NotRoleSetter());
    // audit-bug: no nonce or signer epoch is invalidated when the role changes.
    isWhitelister[creditSide][account] = newIsWhitelister;
}

require(
    recovered != address(0) && recovered == whitelister &&
    ↳ isWhitelister[creditSide][recovered], InvalidSigner()
);
uint256 currentNonce = nonces[creditSide][whitelister][account];
if (nonce == currentNonce) {
    nonces[creditSide][whitelister][account] = currentNonce + 1;
```

```
isWhitelisted[creditSide][account] = newIsWhitelisted;  
}
```

Attack Path

1. A whitelister signs an authorization for an account with the current nonce and a future deadline. The signature is not submitted.
2. The role setter disables the whitelister. The signature cannot be used while the role remains disabled.
3. The role setter later grants the role to the same address again.
4. A holder submits the old signature. `setIsWhitelistedWithSig()` accepts it because the deadline has not passed and the nonce is still current.

Impact

Re-granting the role restores authorizations issued before the revocation.

Discussion

MathisGD

we acknowledge this issue. we don't think that it deserves a fix

Issue L-2: setIsWhitelisted() doesn't increment the nonce, so stale signatures can change the whitelisting status [ACKNOWLEDGED]

Source: <https://github.com/sherlock-audit2/2026-09-morpho-whitelistentergate-sep-9th-2026/issues/6>

This issue has been acknowledged by the team but won't be fixed at this time.

Summary

setIsWhitelisted() sets isWhitelisted[creditSide][account], but doesn't increment nonces[creditSide][whitelister][account], so a malicious user can whitelist itself afterwards using an older signature at the current nonce.

Note that the whitelister can also just submit a new signature, in which case older signatures with different status will revert. But since this new signature and the account's signature with the other status share the same nonce, whichever one arrives first sets the status and the second one reverts.

Vulnerability Detail

A whitelister has two ways to set an account's status:

- setIsWhitelisted();
- setIsWhitelistedWithSig().

The nonce is only incremented when nonce == currentNonce and previous signatures do not revert unless they change the whitelisting status:

```
uint256 currentNonce = nonces[creditSide][whitelister][account];
if (nonce == currentNonce) {
    nonces[creditSide][whitelister][account] = currentNonce + 1;
    isWhitelisted[creditSide][account] = newIsWhitelisted;
} else {
```

```
require(nonce < currentNonce, InvalidNonce());
require(isWhitelisted[creditSide][account] == newIsWhitelisted,
    ↪ WhitelistedStatusChanged());
}
```

However, `setIsWhitelisted()` sets the newest status of the account, but a signature at the current nonce, that was created before the `setIsWhitelisted()` call, can still change it.

Impact

An account the whitelister has directly revoked whitelists itself again.

Code Snippet

https://github.com/sherlock-audit2/2026-09-morpho-whitelistentergate-sep-9th-2026/blob/main/morpho-org__midnight/src/periphery/whitelist-enter-gate/WhitelistEnterGate.sol#L52-L56

https://github.com/sherlock-audit2/2026-09-morpho-whitelistentergate-sep-9th-2026/blob/main/morpho-org__midnight/src/periphery/whitelist-enter-gate/WhitelistEnterGate.sol#L80-L87

Tool Used

Manual Review

Recommendation

Increment `nonces[creditSide][msg.sender][account]` in `setIsWhitelisted()`. This way a whitelister that revokes an account also cancels the stale signature they previously signed. The fix is still not bullet proof since there may be multiple whitelisters, so a signature from another whitelister can still change the status, but that would require a bigger refactor (like adding a per account epoch mapping which disables all previous signatures from all whitelisters, and introduces a new cross whitelister relationship).

Disclaimers

Blackthorn does not provide guarantees nor warranties relating to the security of the project.

Usage of all smart contract software is at the respective users' sole risk and is the users' responsibility.